

Design and Implementation of a Security Vulnerability Practice Testbed in Agentic LLM Environments

Seokjae Gwon¹[0009-0009-5910-3024]*, Esther Kim²[0009-0006-5768-4695]**,
HuiJin Lim³[0009-0008-7015-3818], Nahyun Kim⁴[0009-0004-3386-6932], and
Seyoung Lee⁵[0000-0002-8277-8486] ***

¹ Department of Computer Engineering, Kangwon National University, Chuncheon, South Korea

`obtsj@kangwon.ac.kr`

² Department of information Security, Seoul Women's University, Seoul, South Korea

`seudeoest@swu.ac.kr`

³ Department of Computer Engineering, Mokwon University, Daejeon, South Korea

`gabriel227@mokwon.ac.kr`

⁴ Department of Applied Artificial Intelligence, Seoul National University of Science and Technology, Seoul, South Korea

`skgus3874@seoultech.ac.kr`

⁵ School of Convergence Security, Kangwon National University, Chuncheon, South Korea

`seyoung@kangwon.ac.kr`

Abstract. We have developed an educational, CTF-style testbed that implements the full range of LLM vulnerabilities defined in the OWASP LLM Top 10. To simulate complex, real-world threats, the platform integrates multimodal inputs with GPT-4o function calling, covering scenarios like prompt injection, excessive agency, and data poisoning. Key features include a Korean interface, hidden command recognition via an image OCR module, and real-time visualization of function-calling workflows. A standout "Excessive Agency" challenge demonstrates how privilege escalation can occur through image-based command injection. The platform's educational effectiveness was confirmed through experimental results, where participants' security awareness was quantitatively measured using HAIS-Q and SA-16 surveys. Future plans involve exploring adaptive difficulty and validating an automated detection-patching loop through PoCs in key sectors.

Keywords: Multimodal CTF · OWASP LLM Top 10 · Function Calling · Excessive Agency · Real-time Visualization

* These authors contributed equally to this work.

** These authors contributed equally to this work.

*** Corresponding author: `seyoung@kangwon.ac.kr`

1 Introduction

Large Language Model (LLM)-based applications have advanced into agentic architectures that interface with external systems based on user inputs[5]. However, this progression has introduced significant new security vulnerabilities. The challenge is amplified in multimodal LLM environments, where malicious commands can be concealed not only in text but also within images and audio[1]. Traditional web security models, which do not clearly distinguish between prompt processing, model inference, and external tool use, are unable to effectively mitigate emerging threats like Prompt Injection and Excessive Agency.

2 Background

To address the limitations of text-centric security platforms, we propose an integrated CTF-style testbed that covers the entire range of threats defined in the OWASP LLM Top 10 by simulating realistic multimodal Prompt Injection and Excessive Agency scenarios. While the 2025 “OWASP Top 10 for LLM Applications”[3] identified critical new risks like multimodal command injection, current public platforms (e.g., DVLA, WebGoat-LLM) fail to address these complex vulnerabilities, which stem from multimodal inputs, function-calling abuse, or privilege delegation[4]. This gap prevents learners from building practical skills and is compounded for domestic organizations by the lack of a Korean UI and quantitative evaluation features.

To bridge this, our testbed implements all ten OWASP risks, featuring multimodal prompt injection, real-time visualization of tool-calling, and quantitative simulation of excessive privilege delegation, offering a more comprehensive and accessible training solution.

3 Implementation of the LLM Security Vulnerability Testbed

3.1 CTF Platform and Design Principles

Our platform is an educational testbed that enables learners to experience all ten vulnerability categories from the 2025 OWASP LLM Top 10 through CTF challenges. Set in a simulated corporate environment, it provides hands-on practice with threats such as prompt injection, excessive agency, and data poisoning, bridging theoretical knowledge with practical defense skills. The system follows a visualized workflow: Input → Policy Validation → LLM Inference/Function Calling → External Tool Execution → Response. Built on Streamlit, the interface accepts text and image inputs, using an OCR module to extract hidden commands from images. These inputs are processed by a GPT-4o model configured with Korean system prompts. Upon triggering function calls, external services like the Resend email API and Supabase database are invoked. User API keys are secured via Fernet symmetric-key encryption. The full architecture is shown in Figure 1.

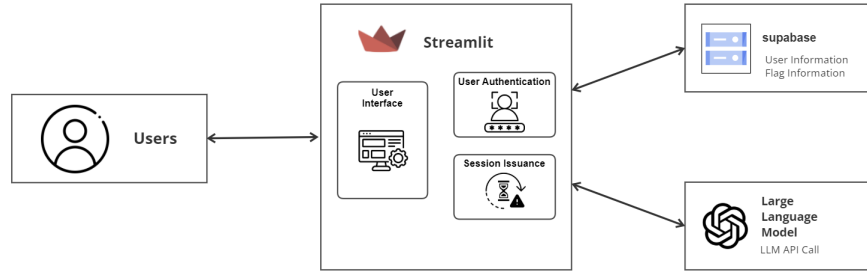


Fig. 1. Architecture of the CTF Testbed based on OWASP LLM Top 10

3.2 Implementation of the Excessive Agency Scenario

To maximize educational effectiveness, the scenario was designed to allow users to intuitively experience a chained attack within an agentic LLM environment. In this setup, when a user requests to send an email to an administrator, the LLM misinterprets the recipient field "to" as the sender field "from", inadvertently granting elevated privileges. This reproduces a common semantic ambiguity in Korean-language prompts, where misinterpretation leads to unintended privilege escalation—a behavior consistent with the Excessive Agency vulnerability caused by ambiguous instructions, as outlined in the OWASP LLM Top 10.

Subsequently, a multimodal prompt injection guide is delivered to the user's account via the Resend API, leading the user to upload an image containing a hidden instruction. The platform extracts embedded text from the image using an OCR module, bypassing security policies and escalating the user's privileges to super-administrator. The user then accesses a restricted database and retrieves sensitive information, demonstrating how prompt injection and excessive agency can combine to create critical security risks in real-world operational environments.

3.3 Differentiation from Existing Platforms and Educational Impact

The proposed testbed offers clear differentiation from existing training platforms. Notably, it is the first in Korea to implement multimodal prompt injection—a newly emerging threat demonstrated at international conferences such as Black Hat Europe.[2] This vulnerability, which has surfaced with the advancement of vision-capable LLMs like GPT-4, remains largely unaddressed in conventional platforms. Furthermore, the testbed utilizes GPT's Function Calling to visually illustrate how an agentic LLM invokes external tools and its parameters can be manipulated. This allows users to intuitively grasp the risks of excessive agency by simulating how malicious input in over-privileged scenarios leads to function misuse and privilege escalation. A Korean-language interface and YAML-based scenario configuration ensure both usability and extensibility. As presented in Table 1, our testbed comprehensively incorporates these advanced

Table 1. Comparison of Feature Support: Existing Platforms vs. Proposed Testbed

Feature	PortSwigger	DVLA	Proposed Testbed
OWASP LLM Top 10 Coverage	Partial	Partial	Full
Multimodal Injection Support	Not Supported	Not Supported	Supported
Visual Simulation of Function Calling	Not Supported	Not Supported	Supported
Authorization Bypass and Agentic Exploits	Not Supported	Not Supported	Supported
Korean Interface and Documentation	Not Available	Not Available	Available
Modular Architecture	Partial Support	Partial Support	Fully Modular
Scenario Expansion via YAML Configuration	Not Supported	Not Supported	Supported
Domain Integration Readiness	Not Supported	Not Supported	Supported

security elements—including multimodal input handling and function call simulation—providing a more realistic training environment than prior platforms.

3.4 Design of a Survey Instrument to Assess the Educational Impact of LLM Security Training

To evaluate the CTF platform’s educational effectiveness, we developed a structured survey using validated information security instruments. Each item was adapted from reliable existing tools and tailored to the context of LLM-specific vulnerabilities.

The survey covers key domains to evaluate the educational impact of the CTF platform. First, HAIS-Q-based items were adapted to assess participants’ knowledge, attitudes, and behaviors related to LLM security. Second, retrospective pre-post items using the SA-16 framework captured changes in security attitudes across engagement, attentiveness, resistance, and improvement intent. Additional items measured self-perceived awareness shifts after the CTF experience, while objective multiple-choice questions assessed knowledge acquisition on LLM vulnerabilities. This multi-layered structure offers a robust foundation for evaluating how effectively the platform enhances participants’ understanding and awareness of LLM security issues.

4 Conclusion

We designed and implemented CTF challenges based on the OWASP LLM Top 10, with a key scenario simulating how Excessive Agency is exploited via multimodal inputs and GPT-4o’s Function Calling. To enhance practical skills, the testbed features a Korean interface and visualized logging. We also established a framework to quantitatively assess its educational impact using HAIS-Q and SA-16 surveys. Future work will focus on introducing adaptive scoring and validating a detection-patching automation loop through PoCs in key industrial domains like finance and healthcare.

References

1. Das, B.C., Amini, M.H., Wu, Y.: Security and privacy challenges of large language models: A survey **57**(6) (2025). <https://doi.org/10.1145/3712001>, <https://doi.org/10.1145/3712001>
2. Nassi, B., Rokach, L., Elovici, Y.: Indirect prompt injection attacks on multi-modal llms. In: Black Hat Europe 2023 (2023), <https://i.blackhat.com/EU-23/Presentations/EU-23-Nassi-IndirectPromptInjection.pdf>
3. OWASP Foundation: OWASP LLM Top 10. <https://genai.owasp.org/llm-top-10/> (2025), last accessed 24 July 2025
4. ReverseSecLabs: Damn Vulnerable LLM Agent. <https://github.com/ReverseSecLabs/damn-vulnerable-llm-agent> (2025), last accessed 24 July 2025
5. Wang, L., Ma, C., Feng, X., Zhang, Z., Yang, H., Zhang, J., Chen, Z.Y., Tang, J., Chen, X., Lin, Y., Zhao, W.X., Wei, Z., Wen, J.R.: A survey on large language model based autonomous agents. *Frontiers of Computer Science* (2025). <https://doi.org/10.1007/s11704-024-40231-1>, <https://doi.org/10.1007/s11704-024-40231-1>

Acknowledgments

This work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP)-Innovative Human Resource Development for Local Intellectualization program grant funded by the Korea government (MSIT)(IITP-2025-RS-2023-00260267) and by the "Convergence and Open Sharing System" Project, supported by the Ministry of Education and the National Research Foundation of Korea.